

Warsaw, January 18, 2024

Decision

DKN.5131.53.2021

Based on Article 104 § 1 of the Act of June 14, 1960, the Code of Administrative Procedure (Journal of Laws of 2023, item 775, as amended), hereinafter referred to as "KPA", Article 7 § 1 and Articles 60, 101, and 103 of the Act of May 10, 2018, on the Protection of Personal Data (Journal of Laws of 2019, item 1781), as well as Article 57 § 1 letters a) and h), Article 58 § 2 letters e) and i), Article 83 § 1 and 2, Article 83 § 4 letter a) in connection with Article 33 § 1 and Article 34 § 1, 2, and 4 of the Regulation of the European Parliament and of the Council (EU) 2016/679 of April 27, 2016, on the protection of natural persons with regard to the processing of personal data and on the free movement of such data, and repealing Directive 95/46/EC (General Data Protection Regulation) (OJ EU L 119 of 04.05.2016, p. 1, OJ EU L 127 of 23.05.2018, p. 2 and OJ EU L 74 of 04.03.2021, p. 35), hereinafter referred to as "Regulation 2016/679", after conducting administrative proceedings initiated ex officio regarding the violation of personal data protection regulations by Mr. B.W., conducting business under the name: B. (...), the President of the Personal Data Protection Office,

1) finds that Mr. B.W., conducting business under the name: B. (...) has violated the provisions: a) Article 33 § 1 of Regulation 2016/679, consisting of failing to notify the President of the Personal Data Protection Office of the personal data breach without undue delay, and no later than 72 hours after becoming aware of the breach, and b) Article 34 § 1 and 2 of Regulation 2016/679, consisting of failing to inform the data subjects without undue delay about the personal data breach, in a manner compliant with the requirements of Article 34 § 2 of Regulation 2016/679,

2) imposes on Mr. B.W., conducting business under the name: B. (...) an administrative fine in the amount of 9,903.60 PLN (in words: nine thousand nine hundred three zlotys and sixty groszy),

3) orders Mr. B.W., conducting business under the name: B. (...) to notify - within 3 days from the date of delivery of this decision - the three individuals specified in this decision, whose data in the form of PESEL numbers were disclosed as a result of the unauthorized disclosure, about the breach of their personal data in order to provide them with the information required under Article 34 § 2 of Regulation 2016/679, namely: a) a description of the nature of the personal data breach; b) the name and contact details of the data protection officer or the designation of another contact point from which more information can be obtained; c) a description of the possible consequences of the personal data breach; d) a description of the measures taken or proposed by the controller to address the breach - including measures to mitigate its potential negative effects.

Justification

On September 13, 2021, the President of the Personal Data Protection Office, hereinafter also referred to as "the President of UODO" or "the supervisory authority", received information about a personal data breach from a third party. According to the information provided, the breach consisted of sending on (...) August 2021 an email to an unauthorized recipient containing an unprotected database (hereinafter referred to as "the Database") - a complete list of participants in the Conference "(...)" scheduled for (...) September 2021 in N. It was indicated that this email was sent by an entity also referred to as "the Administrator": Mr. B.W., conducting business under the name: B. (...). The Database contained, as indicated by the information provided by the third party, data of (...) individuals regarding their: first names, surnames, email addresses, phone numbers, places of employment, positions, payment statuses for participation in the conference, and health-related data (information about being vaccinated or not).

In connection with obtaining the aforementioned information, the supervisory authority requested appropriate explanations from the Administrator regarding the aforementioned incident. However, establishing the factual state in cooperation with the Administrator proved to be lengthy and difficult, not only due to the untimeliness of the information provided by him. At one point, it even became necessary for the President of UODO to contact the data protection officer (hereinafter: "DPO") designated by the unauthorized recipient of the email containing the Database to fully clarify the

circumstances of the breach. The information provided by this last entity and the materials submitted by it (including, among others: a screenshot revealing the sender and recipient of the email containing the Database, as well as a file containing the Database, which evidence the President of UODO found credible regarding the data resulting from them) along with the other explanations provided by the Administrator (which were sometimes contradictory to the evidence and information provided by the DPO designated by the unauthorized recipient and were deemed unreliable in this regard) allowed for the establishment of the following sequence of events: - on (...) August 2021, (...) X. Z., signed as (...), sent an email from the address: (...) to the address: (...); - The domain: (...) belongs to Y. sp. z o.o. with its registered office in P. (hereinafter also referred to as "the Company"), to which the email was sent.

the subject message, and this address was used by Mr. B.W. during the period in which he collaborated with this Company (i.e., until the first quarter of 2021, when the agreement connecting these two - subsequently conflicting - entities was terminated); - in the footer of the sent message, the website addresses were indicated: (...) and (...), as well as the logos: (...) and (...), which are managed and for which Mr. B.W., conducting business under the name B. with its registered office at: ul. (...); - the aforementioned email did not contain content, but only an unsecured attachment that could be read by unauthorized persons, in which the Database was located; - the personal data contained in (...) rows of this Database sometimes repeats, so the actual number of individuals affected by the breach is smaller (the breach concerned the personal data of (...) individuals); - the categories of personal data contained in the Database varied in the case of individual entities. There were data of the aforementioned individuals regarding: first names, surnames, data of the business entities with which these individuals were professionally associated and the functions they held, email addresses, phone numbers, and NIP numbers (where, in the case of three individuals, instead of NIP numbers, their PESEL identification numbers were entered). Additionally, the Database contained data concerning the health of some individuals (information about being vaccinated or not), as well as information (though not in every case) about the number of tickets, their type (accommodation), the number of individuals using the accommodation, pro forma invoices, and the payment status for participation in the conference; - part of the data contained in the Database (insignificant, as it concerned only (...) individuals and in varying degrees not related in any case to the PESEL identification number) was previously known to the Company; some of this data is also available on the Internet, as demonstrated by the Administrator (in a scope not overlapping in any case with the entirety of the data contained in the Database); - the Company informed the individuals whose data was contained in the Database about the incident - this information did not contain elements required under Article 34(2) of Regulation 2016/679, and the Administrator did not demonstrate that in the case of individuals whose PESEL identification numbers were in the Database, these elements were included in the information provided by him over the phone. As previously indicated, obtaining information from the Administrator was difficult, and his explanations were not consistent. To demonstrate the correctness of the supervisory authority's determination of the factual state (and to illustrate the difficulties caused by the Administrator's attitude), the course of events is described below. This description also clarifies the basis on which the President of the UODO established the factual state of the case - i.e., to what extent and which statements (of the Administrator and the DPO appointed by the Company, which was the unauthorized recipient of the email) were believed, and which (and for what reasons) the supervisory authority refused to accept as credible. After receiving information about the sending of an email containing the Database to an unauthorized recipient, on September 24, 2021, the supervisory authority sent a request for clarification to the Administrator, indicating, among other things, the obligations arising from Article 33(1) and (3) of Regulation 2016/679 and requested, based on Article 58(1)(a) and (e) of Regulation 2016/679, information on whether, in connection with the aforementioned situation, an analysis of the incident was conducted in terms of the risk of violation of the rights or freedoms of individuals necessary to assess whether there was a breach of personal data protection, resulting in the necessity to notify the President of the UODO and the individuals affected by the breach. This letter also indicated to the Administrator how to report the breach. In response to the above, the Administrator, in a letter received by this Office on October 11, 2021, explained that, among other things: "(...) there was no need to notify the President of the Office for Personal Data

Protection and the individuals affected by the breach” and that this disclosure occurred as a result of an unintentional sending of an email to an address that an unauthorized person had access to [quote: “(...) the address to which it was disclosed is the address of the company Y. sp. z o.o. with which I had a (terminated at the beginning of this year) civil law agreement”]. The supervisory authority, in a letter dated October 12, 2021, indicated (referring to the content of the aforementioned letter from the Administrator) that in the given situation, the arguments raised by the Administrator that: “(...) this company was the sole administrator of the account (email address). I was never responsible for the existence of this address, its management, or configuration,” “(...) I ended my cooperation with the aforementioned company at the beginning of this year and since then I have not used this email address,” and that “if the address had been properly and necessarily deleted, the message containing personal data would not have reached the indicated address at all, because a message sent to an incorrect address would simply have been rejected by the mail server.” The supervisory authority, in response to the arguments raised by the Administrator, also pointed out that in the case where a data controller discloses data to an unauthorized person - even if such “situation was a one-time, incidental” - he must analyze this event in the context of Article 4(12) of Regulation 2016/679 - according to which “a personal data breach” means a breach of security leading to the accidental or unlawful destruction, loss, alteration, unauthorized disclosure, or unauthorized access to personal data transmitted, stored, or otherwise processed. The President of the UODO indicated that such a breach undoubtedly occurred in the situation described above, hence the Administrator's statement that: “(...) there are no grounds for taking action” seems unjustified.

by mail on 16 February 2022) indicated, among other things, that: “(...) all the data of the aforementioned (...) individuals (in terms of: first name, last name, email address, phone number, place of employment, position, i.e., the data contained in the email sent to the unauthorized recipient) are publicly available. This information is accessible on the professional profiles of these individuals on social media platforms, such as LinkedIn, and is also available on the websites of their respective employers.”

Furthermore, the Administrator stated that: “(...) the individuals concerned have not raised any objections regarding the disclosure of their data, and they are aware that their professional information is publicly available.”

In light of the above explanations, on 1 March 2022, the supervisory authority issued a decision to conclude the administrative proceedings, stating that the Administrator had provided sufficient evidence to demonstrate that the data in question was publicly available and that the risk of violation of the rights or freedoms of the individuals concerned was low.

The decision emphasized that the Administrator had taken appropriate measures to ensure the security of personal data and had conducted a thorough analysis of the incident. The supervisory authority also noted that the Administrator had cooperated fully during the investigation and had implemented additional security measures to prevent similar incidents in the future.

The decision was communicated to the Administrator on 5 March 2022.

only on February 21, 2022) explained that:

“All individuals whose data has been indicated in the email are professionally associated with broadly understood hospitality and gastronomy industries, including catering. Their data enabling participation in the conference (the only data contained in the email) is either publicly available on the internet or can be obtained by contacting not so much [the] individual, but often even by contacting the entity with which the individual is professionally associated, e.g., the relevant hotel, restaurant, or a company engaged in catering activities.” Furthermore, the Administrator requested: “(...) to conduct (...) appropriate evidentiary proceedings (evidence) (...) by entering individual email addresses as a search phrase to show that these addresses are or were (as of the date of sending the disputed email) publicly available (searching for the phrase with the email address will result in obtaining a webpage containing other data assigned to that address, such as first and last name or the name of the 'company' - a company from the hospitality and gastronomy industry).” The Administrator also requested to conduct evidence from the Central Register and Information on Economic Activity and the

Register of Entrepreneurs of the National Court Register.

In a letter dated March 7, 2022, the President of the UODO (responding to the content of the aforementioned administrator's response) indicated that the Administrator did not answer all the questions posed to him, and that the supervisory authority does not possess email addresses (...) of the individuals whose data is the subject of the violation in question (at this stage, the supervisory authority did not have any personal data in the Database, which made it impossible to search for individual data on the Internet or in any registers). Furthermore, the supervisory authority noted that according to previous findings, the email sent to the unauthorized recipient contained data regarding the first name, last name, email address, phone number, place of employment, position, payment status for participation in the conference, and health-related data (information about being vaccinated or not), and not only the email address, first name, last name, and company name. In light of the above, acting under Article 58(1)(a) and (e) of Regulation 2016/679, the President of the UODO again requested the submission of (previously not provided) explanations within 7 days from the date of delivery of this letter, as well as to indicate the website addresses (links to pages) where the data assigned to (...) email addresses of individuals affected by the violation of personal data protection are located or screenshots with visible data of these 91 individuals found on those pages (with visible addresses of those pages). This request was delivered on March 18, 2022.

In a letter received by this Office on April 11, 2022 (which was sent on April 5, 2022), the Administrator explained that: "all data of all ninety-one individuals is or was at the time of data transmission publicly available; they are made available in the Central Register and Information on Economic Activity, National Court Register (including registration documents)." In this letter, the Administrator additionally informed about a lawsuit filed against him by the Company that was the unauthorized recipient of the data and that he himself also filed a lawsuit against this Company. However, regarding the indication of the websites where the relevant data assigned to (...) individuals are located, the Administrator requested: "(...) an extension of the deadline for providing a response by another 14 days, as gathering the necessary data requires a significant amount of time (...)," but no additional correspondence in this regard was received by the Office until July 18, 2022, when the Administrator responded to the request for explanations sent to him by the President of the UODO on July 8, 2022. These explanations (sent on July 14, 2022) included screenshots showing certain categories of personal data of slightly more than (...) individuals (in cases where their first names, last names, email addresses, phone numbers, or the fact that they held certain positions in various entities were visible - but not in every case did the scope of the publicized data cover all these categories). The screenshots sent did not show data regarding whether any of the individuals were vaccinated or not.

Due to the discrepancy in the number of individuals whose data was affected by the violation and the lack of the possibility to verify whether the screenshots actually reveal the data of individuals affected by the violation of personal data protection, a request was made to the DPO appointed by the Company, which became the unauthorized recipient of the email containing the Database, to provide the content of this email along with the attachment containing the relevant personal data. Upon receiving it, the supervisory authority found that the data contained in (...) rows of the table sometimes repeats, so the actual number of individuals affected by the violation is smaller (the violation concerned the personal data of (...) individuals). The categories of personal data contained in the Database varied in the case of individual entities. It contained data of the aforementioned individuals regarding: first names, last names, data of business entities with which these individuals were professionally associated, and the positions they held, email addresses, phone numbers, and NIP numbers (in the case of three individuals, instead of NIP numbers, their PESEL identification numbers were entered). Furthermore, the Database contained health-related data of some individuals (information about being vaccinated or not), as well as information (though not in every case) about the number of tickets, their type (accommodation), the number of individuals using accommodation, proforma invoices, and payment status for...

Participation in the conference. From the information provided by the Data Protection Officer (DPO) of the Company, which is an unauthorized recipient of the aforementioned data, it also emerged that the

email in question was sent from the email address (...) (...) X. Z. (signed as (...)). The email was sent to the address: (...), with the domain: (...) belonging to the Company (the unauthorized recipient).

Due to, among other things, the aforementioned discrepancies, a request for clarification was made to the Administrator on March 17, 2023, with a deadline of 7 days from receipt of the summons. The correspondence containing the first summons was not received by the Administrator. The second summons sent on April 21, 2023, was received on May 9, 2023. The Administrator first requested an extension of the deadline for responding to the summons until May 23, 2023, and after receiving information about its extension from the supervisory authority in accordance with the request, provided a response by sending a letter only on June 1, 2023 (again exceeding the designated deadline).

In the aforementioned clarifications dated June 1, 2023, the Administrator informed that no part of his letter dated July 14, 2022 (containing screenshots) indicates that it concerned only a portion of the personal data contained in the Database, and the thesis that it was so is incorrect. Furthermore, the Administrator indicated that the place of publication of the PESEL identification numbers contained in the Database is the National Court Register and also that the function of the register of personal data protection violations concerning the entry regarding the subject violation is fulfilled by the correspondence exchanged with the supervisory authority (as violations are not registered in a specific manner).

Given that the President of the Personal Data Protection Office (UODO) obtained from the DPO of the Company, which is an unauthorized recipient of the Database, information that the email in question was not sent personally by Mr. B.W., the Administrator in the aforementioned summons for clarification, which was received on May 9, 2023, was also asked about the role of the person who sent the aforementioned email on (...) August 2021 in the process of processing the personal data contained in the shared Database. The supervisory authority also requested that when the Administrator provides explanations in this regard, he should indicate the reasons why, when responding to the President of UODO on February 14, 2022, to the summons for clarification (which included, among other things, the question "whether the email containing the personal data in question was sent by you personally to an unauthorized person, or was it sent by your employee or another person"), the Administrator stated that "I do not employ any employees who could have access to this data; all actions in this regard I perform and have performed independently."

In the response sent on June 1, 2023, the Administrator indicated that since he does not employ anyone, no one else could have sent the email in question, and he did not send it.

In the aforementioned summons for clarification, ultimately received by the Administrator on May 9, 2023, the supervisory authority summoned Mr. B.W. to clarify whether the unauthorized recipient of the data covered by the Database was in possession of all that data before receiving it via the email sent on (...) August 2021. Doubts in this regard were raised, among other things, by the fact that the Administrator indicated in his letter dated February 14, 2022 (quoted): "Moreover, I collected these addresses myself and gathered and processed them in this way." The Administrator explained in this regard that "(...) I was an employee of the 'unauthorized recipient' and as part of my professional duties, I independently collected, gathered, and processed the data covered by the Database. The information contained in the email from (...) August 2021 did not contain any other data than the data collected while I was an employee of the 'unauthorized recipient,' and for this reason, I know that the 'unauthorized recipient' was in possession of this data" (the fact that the unauthorized recipient was previously in possession of this data and processed it was also indicated by the Administrator in the letter received by the President of UODO on November 17, 2022). In connection with such a statement made by the Administrator, a request was made to the DPO of the Company, which is the unauthorized recipient of the email containing the personal data to which the subject violation pertains, to provide additional information - i.e., whether before receiving the aforementioned email, the Company possessed all the data contained in this Database. The DPO of the entity that became the unauthorized recipient of the personal data informed the President of UODO that the Company did not possess and does not possess the vast majority of the data contained in the sent Database - in its databases, it found possession of data for only (...) individuals or entities, but only regarding their: first

name and surname, company, email address, phone number, and NIP number (where the scope of data possessed in the case of these (...) individuals did not always include all these categories).

In his letter sent on June 1, 2023, the Administrator, among other things, demanded explanations as to why "(...) the President of UODO is even considering that the message was sent by another person, since I did not make such a statement" and refers to the fact that in his earlier explanations he did not include anything from which it could be concluded that the screenshots sent by him concerned only a part of the data contained in the Database. In response to this (first sent on June 21, 2023, and then resent on July 21, 2023, due to the Administrator's failure to address the previous correspondence in a timely manner), the supervisory authority clearly indicated that the content of this Database "is now also known to the President of UODO," and then again demanded explanations. The Administrator clearly overlooked this information and again submitted explanations (in a letter that was received by this Office on August 14, 2023) indicating the assumption that the President of UODO does not possess the message sent on (...) August 2021.

contains the necessary information, but also because it does not adequately inform the data subjects about the nature of the data breach and the potential consequences thereof. The President of UODO emphasized that the notification must include specific details regarding the nature of the personal data breach, the likely consequences of the breach, and the measures taken or proposed to be taken to address the breach.

In response to the ongoing investigation, the Administrator was reminded of the importance of compliance with the obligations set forth in the General Data Protection Regulation (GDPR) and the necessity to ensure that all data subjects are properly informed in accordance with the legal requirements. The President of UODO reiterated that failure to notify the affected individuals in a timely and comprehensive manner could result in further administrative actions, including potential fines or sanctions.

The Administrator was also advised to review and enhance their data protection policies and procedures to prevent similar incidents in the future. This includes implementing appropriate technical and organizational measures to safeguard personal data and ensure compliance with GDPR principles.

In conclusion, the ongoing investigation will continue to assess the circumstances surrounding the data breach, the adequacy of the Administrator's responses, and the measures taken to rectify the situation. The President of UODO will ensure that all findings are documented and that appropriate actions are taken to uphold the rights of the data subjects involved.

was sent by the data administrator concerning the breach, but also due to the lack of the required elements specified in the aforementioned regulation. Furthermore, in the explanations received by the authority on April 11, 2022, the Administrator indicated that he had contacted each of the individuals whose data was in the Database by phone - including to apologize for the incident that occurred. Unfortunately, it remains unclear whether he contacted all individuals actually affected by this breach or only those whose data is visible in the screenshots provided to the supervisory authority (in a letter received on July 18, 2022), as he claimed that the breach only concerned approximately (...) individuals. In a letter dated October 2, 2023, the Administrator explained that: "(...) each of these individuals was informed by phone that their data in the form of first name, last name, address, possibly regarding vaccination status, and other characteristics specific to each individual, had been sent to my old email address, which is an address to which I no longer have access and which is administered by the company (...). I chose this form because I know these individuals and according to previous conversations, this method of contact allowed for the quickest way to reach them, i.e., for them to become aware of this fact. According to my conversations with these individuals, they use email, but due to professional obligations, they are unable to keep up with the detailed content of messages, while they almost always answer their phones, except in special cases." Given the content of these explanations and the fact that the Administrator did not consider it necessary to make these notifications, it cannot be stated that they were in compliance with the requirements of Article 34(1) and (2) of Regulation 2016/679 (as well as with the requirements of Article 12 of the aforementioned

regulation - regarding their form). In the letter dated October 2, 2023, the Administrator also submitted evidentiary requests, which will be discussed below along with the requests submitted in the earlier letter.

Referring to the evidentiary requests indicated by the Administrator in the letter received by this Office on February 22, 2022, namely: 1) conducting evidence "(...) regarding the fact that by searching the internet, and thus in publicly available data, by entering individual email addresses as a search phrase to show that these addresses are or were (as of the date of sending the disputed email) publicly available (searching the phrase with the email address will lead to a result in the form of a website containing other data associated with that address, such as first name and last name or the name of the 'company' - a company from the hospitality and gastronomy industry"; 2) conducting evidence from "registers" due to the fact that: "In the case of (...) first names, last names assigned to a NIP number, and even the address of the entrepreneur, these data still result from publicly available registers - the Central Register and Information on Economic Activity. In the case of individuals holding positions in the management of legal entities or proxies, such a register is the Register of Entrepreneurs of the National Court Register"; and also to the evidentiary requests formulated by the Administrator in the letter dated October 2, 2023, as follows: 3) "(...) The President of the UODO has data enabling him to send summons to all ninety-one individuals to establish the information he requires, including that covered by the summons of September 14, 2023 [note: indicating what information was communicated by the Administrator to the individuals whose PESEL identification numbers were in the Database] and this is what I request"; 4) "(...) to expedite the proceedings and to respond to any possible doubts of the President of the UODO, based on Article 86 of the KPA, I request to be heard as a party. According to this provision, if after exhausting the evidentiary means or due to their absence, there remain unresolved facts significant for the resolution of the case, the public administration authority may hear the party to clarify them," they should be considered irrelevant for the proper establishment of the factual state.

According to Article 78 § 1 of the KPA, the authority conducting the proceedings is obliged to consider the evidentiary request of the party if the subject of the evidence is a circumstance significant for the case. In doctrine, it is accepted that the assessment of whether the subject of the evidence is a circumstance significant for the case or not belongs to the authority, not to the party. This means that the authority conducting the proceedings is not bound by the evidentiary requests of the party. The authority is, however, bound in this regard by the provisions of substantive law that form the basis for the resolution. Therefore, it will be up to the authority to decide whether to admit a given piece of evidence or not. There is no doubt that the authority should first consider whether the circumstance for which the party has invoked an evidentiary means requires proof.

According to the judgment of the Supreme Administrative Court of August 4, 2017 (case no. I OSK 1607/16, LEX no. 2345355), in every proceeding, the authority has an obligation to gather evidence that is significant for the resolution of the case and to make the necessary factual findings based on it. However, what factual findings are necessary for resolving the case is determined by correctly interpreted provisions of substantive law, not by the subjective conviction of the party. No authority conducting proceedings is obliged to conduct all evidence requested by the party. The evidentiary means indicated by the party cannot be disregarded only if the disputed facts significant for the resolution of the case have not been clarified. This means that only the failure to establish circumstances significant for the case can be considered a violation of the rules.

procedures that could affect the content of the factual findings, and consequently the content of the ruling concluding the proceedings in the given case. The entitlement of the party provided for in Article 78 of the Administrative Procedure Code (KPA) is subject to limitations due to the purposefulness and speed of the proceedings. The authority may disregard a request for evidence if it aims to prolong the case (Judgment of the Supreme Administrative Court of November 29, 2016, case no. II GSK 3322/15, LEX no. 2230883). The President of the Personal Data Protection Office (UODO) deemed the evidence requests indicated by the Administrator as irrelevant to the case, as in his opinion, the evidence gathered in the case is sufficient for its resolution, and the authority is not obliged to consider

all requests from the party.

The data contained in the Database, which were also available on the Internet, were submitted to the President of UODO by the Administrator in a letter dated July 14, 2022 (at the stage of requests submitted by the Administrator in a letter dated February 22, 2022, the supervisory authority did not possess the data contained in the Database). Therefore, it should be assumed that the Administrator, summoned again by the President of UODO on July 8, 2022, based on Article 58(1)(a) and (e) of Regulation 2016/679, to indicate the addresses of websites (links to pages) where data assigned to (...) email addresses of individuals affected by the infringement in question or screenshots with visible data of those ninety-one individuals located on those pages (with visible addresses of those pages) presented on July 14, 2022, all data found by him, available on the Internet (thereby fulfilling the action he had previously requested). However, as previously stated in the justification of this decision, the data presented by the Administrator visible on the screenshots do not correspond to all the data contained in the Database. Furthermore, both on the Internet and in the registers indicated by the Administrator (mentioned in point 2 above), there is no information that corresponds to the data contained in the Database regarding, for example, whether a given person is vaccinated or not.

Referring then to the two remaining requests (contained in the letter dated October 2, 2023), it should be noted that the Administrator provided explanations regarding the content of the notifications of personal data breach submitted by him "out of caution" (in the same letter dated October 2, 2023), thus directing requests to the individuals indicated in the Database would only lead to unnecessary prolongation of the proceedings. As for the request to hear the Administrator as a party (mentioned in point 4 above), at this stage of the administrative proceedings, the supervisory authority did not find any doubts that would need to be clarified by the testimony of the Administrator, and additionally deemed that the gathered evidence is sufficient to issue an administrative decision (which was communicated to the Administrator in a letter dated November 21, 2023).

Therefore, taking the above into account, it should be concluded that the evidence requests submitted by the Administrator regarding the matters referred to in points 1-4 above concern circumstances that are irrelevant to the case, and thus their realization would be pointless. The Administrator exercised his right on December 8, 2023, to familiarize himself with the case files, which included, among other things, a screenshot showing the sender and recipient of the email containing the Database, as well as the Database file (which data was provided to the supervisory authority by the Data Protection Officer of the Company, which was an unauthorized recipient of that message). Subsequently, on December 15, 2023, he sent a letter containing a summary of his position in the matter. The Administrator did not dispute the information visible on the aforementioned screenshot or contained in the Database file. However, he reiterated that the inaction of Company Y. sp. z o.o. based in P. regarding the removal of the email address used by the Administrator while cooperating with that company (i.e., until the end of March 2021) "(...) led to the possibility of the email reaching an unauthorized address." Moreover, he emphasized that none of the individuals affected by the breach "came forward in the proceedings" or made any claims, which, in the Administrator's opinion, also proves that "these data were not protected by these individuals from disclosure, and therefore should be considered publicly available, since none of these individuals expects their protection."

The Administrator also indicated that his financial situation had not changed - the activity he conducts (...). After reviewing all the evidence collected in the case, the President of the Personal Data Protection Office considered the following:

According to Article 4(12) of Regulation 2016/679, "personal data breach" means a breach of security leading to the accidental or unlawful destruction, loss, alteration, unauthorized disclosure of, or unauthorized access to personal data transmitted, stored, or otherwise processed. Article 33(1) and (3) of Regulation 2016/679 states that in the case of a personal data breach, the administrator shall notify the supervisory authority competent under Article 55 without undue delay - where feasible, not later than 72 hours after becoming aware of the breach, unless it is unlikely that the breach will result in a risk to the rights or freedoms of natural persons. Any notification submitted to the supervisory authority after 72 hours shall be accompanied by an explanation of the reasons for the delay. The notification

referred to in paragraph 1 must at least: a) describe the nature of the personal data breach, including, where possible, the categories and approximate...

the individuals concerned, as well as the categories and approximate number of entries of personal data affected by the breach; b) include the name and contact details of the data protection officer or the designation of another contact point from which more information can be obtained; c) describe the possible consequences of the personal data breach; d) describe the measures taken or proposed by the controller to address the personal data breach, including, where appropriate, measures to minimize any potential negative effects.

Furthermore, Article 34(1) of Regulation 2016/679 states that in the event of a high risk to the rights or freedoms of natural persons resulting from a personal data breach, the controller is obliged to notify the data subject without undue delay about the breach. According to Article 34(2) of Regulation 2016/679, a proper notification should: 1) describe the nature of the personal data breach in clear and plain language; 2) include at least the information and measures referred to in Article 33(3)(b), (c), and (d) of Regulation 2016/679, i.e.: a) the name and contact details of the data protection officer or the designation of another contact point from which more information can be obtained; b) a description of the possible consequences of the personal data breach; c) a description of the measures taken or proposed by the controller to address the personal data breach, including, where appropriate, measures to minimize any potential negative effects.

From the analysis of the aforementioned provisions, it follows that depending on the level of risk of infringement of the rights or freedoms of natural persons that the controller is dealing with, their obligations towards the supervisory authority and the data subjects differ. If, as a result of the analysis, the controller determines that the likelihood of a risk to the rights or freedoms of natural persons is low, they are not obliged to report the breach to the President of the Personal Data Protection Office. The indicated breach must only be recorded in the internal register of breaches. In the case of identifying a risk to the rights or freedoms of natural persons, the controller is obliged to report the personal data breach to the President of the Personal Data Protection Office, as well as to make an entry in the internal register of breaches. The occurrence of a high risk to the rights or freedoms of natural persons, in addition to an entry in the register of breaches, requires the controller to take appropriate actions, both towards the supervisory authority (reporting the personal data breach) and towards the data subjects.

In the case of personal data breaches that may pose a high risk to the rights or freedoms of the data subject, Regulation 2016/679 introduces an additional obligation for the controller to promptly notify the data subject, unless they have taken preventive measures before the breach occurred or remedial actions after the breach occurred (Article 34(3) of Regulation 2016/679).

As follows from the above, in the event of the controller detecting a personal data breach, it is first necessary to conduct an analysis regarding the risk of infringement of the rights or freedoms of natural persons. The controller is exempt from the obligation to notify the supervisory authority about the breach if the conducted assessment shows that there is at most a low probability of the occurrence of a risk to the rights or freedoms of natural persons. However, it should be borne in mind that the supervisory authority may request the controller to justify the decision not to report the breach; therefore, the conclusions from the conducted analysis should be recorded in the internal register of breaches. The fact that the

Controller was requested by a letter dated April 21, 2023, to provide the supervisory authority with a copy of the register of breaches to the extent that it includes an entry regarding the personal data breach involving the disclosure of the Database to an unauthorized recipient, explained that they do not register breaches in a specific manner raises questions about the Controller's competencies regarding the processing of personal data and their knowledge of its fundamental principles (in particular, Article 5(2) of Regulation 2016/679).

At this point, it is also worth recalling that in Guidelines 9/2022[2], there are recommendations from the European Data Protection Board (hereinafter: "EDPB") regarding the requirement to report personal

data breaches to the supervisory authority. Reporting personal data breaches by controllers constitutes an effective tool contributing to a real improvement in the security of personal data processing. By reporting a breach to the supervisory authority, controllers inform the President of the Personal Data Protection Office whether, in their assessment, there is a high risk of infringement of the rights or freedoms of the data subjects and—if such a risk exists—whether they have provided the relevant information to the individuals affected by the breach. In justified cases, they may also convey that notification is not necessary in their opinion due to the fulfillment of the conditions specified in Article 34(3)(a) and (b) of Regulation 2016/679. The failure to report a personal data breach deprives the supervisory authority of the opportunity to respond appropriately to the breach, which could mitigate its effects. This response involves not only assessing the risk of infringement to the rights or freedoms of the data subject (to which the supervisory authority may require the controller to fulfill the obligation under Article 34(1) of Regulation 2016/679) but also, in particular, verifying whether the controller has taken appropriate measures to address the breach and minimize the negative effects for the meaning of something that is not expected to happen, but does not imply that there is no risk at all. Therefore, the assessment of the likelihood of a risk materializing should be approached with caution, especially in cases where the data involved may lead to various levels of risk for the rights or freedoms of individuals.

In this context, the Administrator has not demonstrated that the aforementioned risk assessment was conducted correctly. In response to two requests to present such an assessment, the Administrator merely stated that, in their opinion, it is unlikely that the breach in question would result in a risk to the rights or freedoms of individuals, indicating that "the data of individuals did not contain particularly sensitive information such as PESEL numbers or bank account numbers," which, in the case of three individuals whose PESEL identification numbers were included in the Database, remains a completely unfounded argument.

Evaluating the Administrator's position cited above, it should be noted at the outset that the scope of data disclosed to the unauthorized recipient was not identical for each of the (...) individuals (hereinafter also referred to as "Data Subjects") whose data was included in the Database. This fact results in varying levels of risk regarding the infringement of the rights or freedoms of these individuals. The Database, as previously indicated, contained personal data regarding (not always the same): first names, last names, data of business entities with which the Data Subjects were professionally associated, and the functions they performed, email addresses, phone numbers, and NIP numbers. The Database included health-related data of some individuals (information about being vaccinated or not), as well as information (though not in every case) about the number of tickets, their type (accommodation), the number of people using the accommodation, proforma invoices, and the payment status for participation in the conference. Individuals whose scope of disclosed personal data did not exceed the aforementioned will be referred to as "Group A Individuals." Meanwhile, three individuals, in whose cases PESEL identification numbers were entered in the Database instead of NIP numbers, will be referred to in the further part of this decision as "Group B Individuals."

Next, when assessing the aforementioned position of the Administrator, it should be emphasized that there are situations where there is a low probability that a breach of personal data will result in a risk of infringement of the rights or freedoms of individuals (which usually justifies the lack of an information obligation under Article 33(1) of Regulation 2016/679) and situations where there is a high risk of infringement of the rights or freedoms of individuals (where, in addition to the obligation under Article 33(1) of Regulation 2016/679, an additional obligation under Article 34(1) of this Regulation often arises), as well as "intermediate" cases, the existence of which cannot be overlooked. In such cases, merely recording the breach in the Administrator's breach register is usually insufficient. It should be emphasized here that "low probability" of the occurrence of an effect in the form of an infringement of the rights or freedoms of the data subject should be equated with a situation where the evaluator has grounds to conclude that this effect will not materialize at all - thus, when we speak of "no risk."

It is worth noting that in the Polish version of Regulation 2016/679, the term "mało prawdopodobne" is used, while in the English version, the term "unlikely" is employed. This word has the meaning of

something that is not expected to happen, but does not imply that there is no risk at all. Therefore, the assessment of the likelihood of a risk materializing should be approached with caution, especially in cases where the data involved may lead to various levels of risk for the rights or freedoms of individuals.

stronger meaning than our native equivalent and is used to define something that is rather improbable, questionable, or almost impossible. It is also worth referring here to Guidelines 9/2022 - especially to Section II of these Guidelines concerning Article 33 of Regulation 2016/679 and the resulting obligation to notify the supervisory authority. In Chapter D of this section, the EDPB discussed the conditions under which such notification is not required - a thorough analysis of the content of this chapter allows us to conclude that the EDPB holds the position that the exception in Article 33(1) of Regulation 2016/679 (i.e., the case where there is no obligation to report a personal data breach to the supervisory authority due to the low probability of a breach of the rights or freedoms of natural persons) should be understood narrowly - in other words: as an exception that will apply in situations where that probability is obviously low. Article 33(1) of Regulation 2016/679 does not contain a list of cases in which the reporting of a personal data breach to the supervisory authority is an obligation of the controllers. This is a deliberate measure, allowing these entities to make a thoughtful decision regarding the final assessment of the potential consequences of such a breach. This freedom allows for the necessary flexibility - it is impossible to foresee all possible cases of personal data breaches in advance, let alone all cases in which the probability that they will result in a risk to the rights or freedoms of natural persons is greater than low. This lack of "automation" resulting from the absence of a closed catalog of cases in which the information obligation under Article 33(1) of Regulation 2016/679 is activated, however, sometimes results in errors on the part of the controllers. Therefore, any risk assessment conducted based on any methodology should be verified by the controller, taking into account the general principles of conducting such an assessment. When applying the provisions of Regulation 2016/679, it should be borne in mind that the purpose of this regulation (expressed in Article 1(2)) is to protect the fundamental rights and freedoms of natural persons, in particular their right to the protection of personal data, and that the protection of natural persons in relation to the processing of personal data is one of the fundamental rights (first sentence of Recital 1 of the preamble). In the case of any doubts, for example, regarding the performance of obligations by controllers - also in situations where a personal data breach has occurred - these values should be considered first. Furthermore, when assessing the risk of infringement of the rights or freedoms of natural persons, the controller should conduct the assessment with appropriate criticism and rationality (which, in the opinion of the supervisory authority, the Controller did not do in this case). In the analyzed factual state, it should be taken into account that in connection with the occurrence of a personal data breach, there were no factors reducing the level of probability of negative consequences, such as: limited ability to identify (both in the case of Persons from Group A and Persons from Group B, the disclosed scope of data allowed for their unambiguous identification), the determination that the personal data is publicly available (see: the Controller's explanations from July 14, 2022, in which the scope of data visible in the screenshots attached to the explanations did not cover all disclosed in the Database), or the recognition of the improper recipient as a "trusted" person. Referring to this last factor, it should be emphasized that the disclosure of the data contained in the Database occurred in a specific context: the email containing it was directed to an unauthorized recipient who was in conflict (subsequently: judicial) with the Controller, which cannot be considered indifferent when assessing the risk of infringement of the rights or freedoms of natural persons associated with the occurrence of a breach of data confidentiality. Although the attitude demonstrated by the unauthorized recipient in actions before the supervisory authority indicated a high degree of lawfulness and care for the interests of Data Subjects, the Controller could not assume in this situation that his conflict with the unauthorized recipient did not affect the risk assessment associated with the occurrence of the personal data breach. Therefore, it should be concluded that there is nothing to support the assumption that it is unlikely that the personal data breach that occurred would result in a risk of infringement of the rights or freedoms of natural persons. The supervisory authority considered such a position justified in relation to Persons from Group A. Even more difficult is it to rationally assume such a low probability in the case of a personal data breach of Persons from Group B. The

President of the UODO, when assessing the risk of infringement of the rights or freedoms of natural persons in this case, even stated that the breach of data confidentiality that occurred in connection with the personal data breach involving the disclosure to an unauthorized entity, among other things, of PESEL identification numbers along with names and surnames and other data of Persons from Group B, poses a high risk of infringement of the rights or freedoms of natural persons. At this point, it should be clarified for the sake of order that due to the lack of specification in the Database of the types of vaccinations, it was not assumed in this case that the disclosure of this data is associated with a high risk of infringement of the rights or freedoms of the relevant Data Subjects. As indicated in Guidelines 9/2022, this risk exists when a breach may lead to physical harm or material or non-material damage to the individuals whose data has been breached (where examples of such damage include discrimination, identity theft or fraud, financial losses, and damage to reputation). There is no doubt that the examples cited in the guidelines...

damage, due to the scope of data covered by this personal data breach, including the PESEL identification number along with the first name and surname and other data, may occur in the discussed case.

Expanding on the above statement, it should be emphasized that the personal data breach that occurred in the case of Individuals from Group B involved the PESEL identification number, which is an eleven-digit numerical symbol that uniquely identifies a natural person, containing, among other things: date of birth and gender designation, and thus is closely linked to the private sphere of the individual and is also subject, as a national identification number, to exceptional protection under Article 87 of Regulation 2016/679 - being data of a special nature and requiring such special protection. Furthermore, it should be taken into account that as a result of the personal data breach, the PESEL identification number was disclosed to an unauthorized person along with the first name and surname and other data of Individuals from Group B contained in the Database, which set of data may be sufficient for "impersonating" the data subject and incurring obligations in the name and to the detriment of such a subject, e.g., financial obligations (see:

<https://www.bik.pl/poradnik-bik/wyludzenie-kredytu-tak-dzialaja-oszusci> - where a case is described in which: "Only the first name, surname, and PESEL number were enough for the fraudsters to defraud several loans totaling tens of thousands of zlotys. Nothing else matched: neither the ID number nor the residential address").

It should be noted that, according to the President of the UODO, consistently raised for many years, the PESEL number is a unique identifier of a person, containing many pieces of information about that person, and its disclosure to an unauthorized person may lead to a number of consequences for such a person.

At this point, it is worth pointing out the Guidelines of the European Data Protection Board 01/2021 regarding examples of reporting personal data breaches adopted on December 14, 2021, version 2.0 (hereinafter "EDPB Guidelines 01/2021"), specifically example number 14, relating to the situation of "accidentally sending highly confidential personal data by mail." In the mentioned case, there was a disclosure of the social security number, which corresponds to the PESEL number used in Poland. In the discussed case, the EDPB had no doubts that the disclosed data regarding: first name and surname, email address, postal address, and social security number indicated a high risk of infringement of the rights or freedoms of natural persons ("the involvement of their [the affected persons'] social security number, as well as other, more basic personal data, additionally increases the risk, which can be described as high"). The EDPB recognizes the importance of national identification numbers (in this case, the PESEL number), while emphasizing that such a personal data breach, thus encompassing data in the form of: first name and surname, email address, postal address, and social security number, requires the implementation of actions, i.e., reporting to the supervisory authority and notifying the individuals whose data are affected.

According to the infoDOK report (which is prepared as part of the social Information Campaign of the RESTRICTED DOCUMENTS System, organized by the Polish Bank Association and some banks, under the patronage of the Ministry of Internal Affairs and in cooperation with, among others, the

Police and the Consumers' Federation), in the first quarter of 2023, there were 2,288 attempts to defraud loans (including one for the amount of 2.6 million zlotys). In the second quarter of 2023, the total amount of thwarted attempts to defraud loans amounted to 50.3 million zlotys, and in the third quarter of 2023: 104.1 million zlotys (including one for the amount of 6 million zlotys).

Moreover, as indicated by the case law, judgments in cases of loan fraud are not uncommon and have been issued by Polish courts in similar cases for a long time - for confirmation, one can mention the judgment of the District Court in Łęczysca dated July 27, 2016 (case file I C 566/15), in which the fraudsters taking a loan on someone else's data used the PESEL number, a fictitious address, and an incorrect ID number (invalid). In the justification of the aforementioned judgment, the Court stated that: "The conducted evidentiary proceedings and analysis of the documents submitted by the plaintiff result in a clear conclusion that in the case under consideration, the defendant was not a party to the loan agreement concluded on May 5, 2014. Although the PESEL number of the defendant J. R. was used at the time of its conclusion, the indicated place of residence does not correspond to the place of residence of the defendant. The defendant J. R. has never lived in W. The loan amount was transferred to an account that was not owned by the defendant. At the time of the conclusion of the loan agreement, ID number (...) lost its validity on March 15, 2014. The mobile phone number indicated in the loan agreement and its attachments does not match the actual phone numbers used by and currently used by the defendant."

Similar doubts (that the disclosure of the PESEL number along with other personal data may pose a high risk of infringement of the rights or freedoms of natural persons) were also held by the Provincial Administrative Court in Warsaw, which in its judgment of September 22, 2021, case file II SA/Wa 791/21, stated that "There is no doubt that the examples of damages cited in the guidelines may occur in the case of individuals whose personal data - in some cases including the PESEL identification number or the series and number of the ID card - have been recorded on the disclosed recordings. The possibility of easy identification of the individuals whose data have been subject to the breach based on the disclosed data is also significant for such an assessment." Furthermore, the Court in the cited ruling indicated that "The data has been...

made available to unauthorized persons, which means that a security breach has occurred leading to the unauthorized disclosure of personal data, and the scope of this data, which in some cases also includes the PESEL identification number or the series and number of the identity card, determines that there is a high risk of infringement of the rights or freedoms of natural persons." Considering the above issues, it is also necessary to refer to the position of the Provincial Administrative Court in Warsaw expressed in the judgment of July 1, 2022, issued in case no. II SA/Wa 4143/21. In the justification of this judgment, the Court stated that: "It should be agreed with the President of UODO that the loss of confidentiality of the PESEL number in conjunction with personal data such as: first name and surname, registered address, bank account numbers, and the identification number assigned to Bank clients - CIF number, is associated with a high risk of infringement of the rights or freedoms of natural persons. In the case of a breach of such data as first name, surname, and PESEL number, identity theft or forgery may occur, resulting in negative consequences for the individuals whose data is concerned. Therefore, the Bank in this matter should have promptly, in accordance with Article 34(1) of the GDPR, notified the individuals concerned about the breach of personal data protection, so as to enable them to take necessary preventive actions." It should also be pointed out the judgment of August 31, 2022, case no. II SA/Wa 2993/21, in which the Provincial Administrative Court in Warsaw emphasized that "(...) the authority rightly assumed that there was a high risk of infringement of the rights and freedoms of individuals affected by the breach due to the possibility of easy identification of the individuals whose data was subject to the breach based on the disclosed data. These data include first name and surname, correspondence address, phone number, and PESEL number of individuals holding Polish citizenship. In this situation, the administrator was obliged to notify without undue delay the individuals concerned about the breach." Similarly, the Provincial Administrative Court in Warsaw expressed itself in judgments of November 15, 2022, case no. II SA/Wa 546/22, and June 21, 2023, case no. II SA/Wa 150/23. As previously indicated in the justification of this decision, it must also be borne in mind that the performance by the Administrator of

his obligation arising from Article 34(1) of Regulation 2016/679 cannot be conditional upon the occurrence of a breach of the rights or freedoms of natural persons whose data is concerned by the breach of personal data protection. It should be noted for the record that the same applies to the obligation arising from Article 33(1) of Regulation 2016/679 - as stated by the Provincial Administrative Court in Warsaw in the judgment of September 22, 2021, issued in case no. II SA/Wa 791/21: "It should be emphasized that the possible consequences of the event do not have to materialize. The content of Article 33(1) of Regulation 2016/679 indicates that the mere occurrence of a breach of personal data protection, which is associated with a risk of infringement of the rights or freedoms of natural persons, implies an obligation to report the breach to the relevant supervisory authority, unless it is unlikely that the breach will result in a risk of infringement of the rights or freedoms of natural persons" (where this Court similarly ruled in the previously cited judgment of July 1, 2022, issued in case no. II SA/Wa 4143/21, as well as in the judgments of August 31, 2022, case no. II SA/Wa 2993/21, November 15, 2022, case no. II SA/Wa 546/22, and April 26, 2023, case no. II SA/Wa 1272/22). As indicated in Guidelines 9/2022, when assessing the risk that may arise from a breach, the administrator should collectively consider the severity of the potential impact on the rights or freedoms of natural persons and the likelihood of its occurrence - of course, the risk increases when the consequences of the breach are more serious, as well as when the likelihood of their occurrence increases (where in case of any doubts, the administrator should report the breach, even if such caution might prove excessive). A high level of either of these factors affects the overall assessment, which determines the fulfillment of the obligations specified in Article 33(1) and Article 34(1) of Regulation 2016/679. Considering that due to the scope of the disclosed personal data of Individuals from Group B in the analyzed case, there was a possibility of significant negative consequences materializing for those individuals whose data is concerned (as demonstrated above), the severity of the potential impact on the rights or freedoms of these individuals should be considered high. At the same time, the likelihood of high risk occurring as a result of the breach in question is not small and has not been eliminated. Thus, it should be stated that in connection with the breach in question concerning Individuals from Group B (in the case of which a specific scope of data was disclosed - (...) individuals), there was a high risk of infringement of the rights or freedoms of the individuals whose data is concerned, which consequently determines the obligation not only to report the breach of personal data protection to the supervisory authority (as is the case with Individuals from Group A) but also to notify about the breach to these three specific Data Subjects. In summary: in the circumstances of the examined case, it cannot be reasonably argued that it is unlikely that this breach would result in a risk of infringement of the rights or freedoms of the Data Subjects in the Database (both Individuals from Group A and B), which in turn results in the Administrator's obligation to report the breach of personal data protection to the supervisory authority, in accordance with Article 33(1) of Regulation 2016/679, which must include the information specified.

Article 33(3) of Regulation 2016/679. Furthermore, in the case of Persons from Group B, there is a high risk of infringement of rights or freedoms, which implies the obligation to notify the affected Data Subjects of the occurrence of a personal data breach in accordance with Article 34(1) of Regulation 2016/679 (which must include the information specified in Article 34(2) of Regulation 2016/679). In the present situation, there are no grounds to conclude that the Administrator was, for any reason, exempt from the obligation to report the personal data breach to the supervisory authority in accordance with Article 33(1) of Regulation 2016/679 and from the obligation to notify Persons from Group B about it (in accordance with Article 34(1) of that regulation).

Due to the fact that the Administrator, after the occurrence of the personal data breach, did not indicate any changes in the personal data processing procedure that would have been prompted by this breach (apart from commissioning an external entity to conduct a data security analysis), it should be noted in the summary of this justification that by allowing the use of email for communication, the Administrator should be aware of the risks associated, for example, with mistakenly sending a message containing personal data to an incorrect recipient. The existence of these risks, in the absence of actions by the data Administrator aimed at minimizing them through the implementation of appropriate organizational and technical measures, such as password-protecting documents sent in this manner, directly leads to

the risk of infringement of the rights or freedoms of natural persons whose data are transmitted via such a communication channel.

Finally, referring to the Administrator's obligation specified in Article 34(2) of Regulation 2016/679, the President of the UODO stated that the Administrator (considering the nature of the breach and the categories of data that were breached) should inform the individuals whose data are affected of the most likely negative consequences of the breach of their personal data. Certainly, in the case of a breach of such data as first name, last name, and PESEL identification number, it is essential to highlight the possible theft or forgery of identity through obtaining loans from non-bank institutions or fraudulently obtaining insurance or funds from insurance, which may lead to negative consequences related to an attempt to attribute responsibility for such fraud to the person whose data have been breached. The description of possible consequences should reflect the risk of infringement of the rights or freedoms of that person, enabling them to take necessary preventive actions.

At this point, it should be noted that according to Article 34(4) of Regulation 2016/679, if the administrator has not yet notified the person whose data are affected about the personal data breach, the supervisory authority—considering the likelihood that this personal data breach will result in a high risk—may require the administrator to do so or may determine that one of the conditions referred to in paragraph 3 has been met. Furthermore, from the content of Article 58(2)(e) of Regulation 2016/679, it follows that each supervisory authority has the power to order the administrator to notify the person whose data are affected about the personal data breach.

Summarizing the above argumentation of the supervisory authority comprehensively, it should be stated that the Administrator—despite updating themselves on the circumstances of the analyzed case of their obligations—did not report the personal data breach to the supervisory authority in fulfillment of the obligation under Article 33(1) of Regulation 2016/679 and did not notify without undue delay the Persons from Group B about the breach of their data, in accordance with Articles 34(1) and (2) of Regulation 2016/679, which constitutes a violation by the Administrator of these provisions.

According to Article 58(2)(i) of Regulation 2016/679, each supervisory authority has the power to impose, in addition to or instead of other corrective measures provided for in Article 58(2)(a) - (h) and (j) of Regulation 2016/679, an administrative fine under Article 83 of Regulation 2016/679, depending on the circumstances of the specific case. The President of the UODO states that in the case at hand, there were grounds justifying the imposition of an administrative fine on the Administrator based on Article 83(4)(a) of Regulation 2016/679, which states, among other things, that a breach of the obligations of the administrator referred to in Articles 33 and 34 of Regulation 2016/679 is subject to an administrative fine of up to 10,000,000 EURO, and in the case of an enterprise, up to 2% of its total annual worldwide turnover from the previous financial year, with the higher amount applying.

In accordance with the provisions of Article 83(2) of Regulation 2016/679, administrative fines are imposed, depending on the circumstances of each individual case, in addition to or instead of the measures referred to in Article 58(2)(a) - (h) and (j) of Regulation 2016/679. In deciding to impose an administrative fine on the Administrator, the President of the UODO—consistent with the provisions of Article 83(2)(a) - (k) of Regulation 2016/679—considered the following circumstances of the case, which necessitate the application of this type of sanction in the present case and which have a burdening effect on the amount of the imposed administrative fine:

1) The nature, gravity, and duration of the infringement, taking into account the nature, scope, or purpose of the processing in question, the number of affected individuals whose data are concerned, and the extent of the damage suffered by them [Article 83(2)(a) of Regulation 2016/679]; In this case, a violation of Article 33(1) of Regulation 2016/679 was found (consisting of the failure to report to the President of the Office for Personal Data Protection).

****Personal Data Breach Notification****

without undue delay, and no later than within 72 hours after the breach is identified) and Article 34(1) and (2) of Regulation 2016/679 (consisting of the failure to properly notify the individuals from Group B, whose data is concerned, about the personal data breach without undue delay). These are related to

an event involving the disclosure of unsecured Database containing personal data of (...) individuals. The categories of personal data contained in the Database varied for each of the subjects - in the case of (...) individuals, their PESEL identification numbers were also disclosed. This makes the situation significant and serious for these three individuals (Individuals from Group B), as this event may lead to material or non-material damages for the person whose data has been breached, and the likelihood of such damages occurring is high. In this case, the personal data breach concerned a relatively large group of individuals. The President of the UODO considers the long duration of the breach by the Administrator of the provisions of Regulation 2016/679 as an aggravating circumstance. More than two years elapsed from the moment he became aware of the personal data breach to the date of this decision, during which the risk of violation of the rights or freedoms of the individuals affected by the breach (especially Individuals from Group B) could have materialized, and these individuals could not counteract this due to the Administrator's failure to fulfill the obligation to report the personal data breach to the President of the UODO and to notify the relevant individuals.

2) ****Intentional Nature of the Breach**** [Article 83(2)(b) of Regulation 2016/679]; According to the Guidelines of the Article 29 Working Party on the application and determination of administrative fines for the purposes of Regulation No. 2016/679 WP253 (adopted on October 3, 2017, approved by EROD on May 25, 2018), intent "includes both knowledge and deliberate action, in relation to the characteristics of the prohibited act." The Administrator made a conscious decision not to report the personal data breach to the President of the UODO nor to properly notify Individuals from Group B about it. There is no doubt that the Administrator, processing personal data on a relatively large scale, must have knowledge in the area of personal data protection, including knowledge of the consequences of identifying a personal data breach resulting in, among other things, a high risk of violation of the rights or freedoms of natural persons. Being aware of this, the Administrator nevertheless decided to refrain from reporting the personal data breach to the President of the UODO and properly notifying Individuals from Group B, despite the fact that the President of the UODO initially informed him of the obligations imposed on the administrator in connection with the personal data breach (i.e., the content of Article 33(1) and (3) of Regulation 2016/679), and also called upon him to provide explanations regarding the risk analysis of the violation of the rights or freedoms of natural persons necessary to assess whether a personal data breach occurred that necessitated notifying the President of the UODO and the affected individuals. The mere initiation by the President of the UODO of this proceeding concerning the obligation to report the personal data breach to the supervisory authority (and subsequently also concerning the notification of the breach in fulfillment of the obligation under Article 34 of Regulation 2016/679) should have raised at least doubts for the Administrator regarding the correctness of his position.

3) ****Degree of Cooperation with the Supervisory Authority to Remedy the Breach and Mitigate its Potential Negative Effects**** [Article 83(2)(f) of Regulation 2016/679]. In this case, the President of the UODO found the cooperation from the Administrator to be unsatisfactory. This assessment pertains to his reaction to the letters from the President of the UODO informing him of the obligations imposed on the administrator in connection with the personal data breach, as well as to the initiation of administrative proceedings regarding the obligation to report the personal data breach (subsequently expanded to include the possibility of violating the obligation under Article 34(1) and (2) of Regulation 2016/679). The actions deemed appropriate by the President of the UODO (reporting the breach to the President of the UODO and properly notifying Individuals from Group B about it) were not taken by the Administrator even after the initiation (or expansion) of the administrative proceedings by the President of the UODO in this matter. The timeliness of the explanations provided by the Administrator also indicated his improper cooperation with the supervisory authority - as did the contradictions and ambiguities concerning them, which did not facilitate the establishment of the factual state in this matter (e.g., the Administrator indicated that he himself collected the personal data contained in the Database, while also contradicting himself by claiming that he did not collect data regarding vaccination status).

4) ****Categories of Personal Data Concerned by the Breach**** [Article 83(2)(g) of Regulation 2016/679].

The Database contained data of natural persons regarding: first names, surnames, data of business entities with which these individuals were professionally associated and the positions they held, email addresses, phone numbers, and NIP numbers (in the case of (...) individuals, instead of NIP numbers, their PESEL identification numbers were entered). Additionally, the Database included health-related data of some individuals (information about vaccination status), as well as information (though not in every case) about the number of tickets, their type (accommodation), the number of individuals using the accommodation, proforma, and the payment status for participation in the conference. In the case of data regarding vaccination status, it should be noted that due to the nature of this information, despite its classification as special categories of personal data, as referred to in...

****Pursuant to Article 9 of Regulation 2016/679, its violation in the present case does not carry a high risk of infringement of the rights or freedoms of natural persons. The personal data disclosed to an unauthorized person does not constitute, in this case, data concerning criminal convictions and offenses referred to in Article 10 of Regulation 2016/679. However, the fact that the database made available to the unauthorized recipient contains a wide range of data (as indicated above) is associated with the risk of infringement of the rights or freedoms of natural persons - and in the case of three individuals from Group B, even with a high risk. The PESEL number, which is an eleven-digit numerical symbol uniquely identifying a natural person, containing the date of birth and gender designation, is closely linked to the private sphere of the individual and is also subject, as a national identification number, to special protection under Article 87 of Regulation 2016/679. It is a data of a special nature and requires such special protection. There is no other, so specific data that would unequivocally identify a natural person. It is not without reason that the PESEL number serves as an identifying data for every person and is widely used in dealings with various institutions and in legal circulation. The PESEL number, along with the first and last name, uniquely identifies a natural person in a way that allows for the attribution of negative consequences of a violation (e.g., identity theft, loan fraud) to that specific individual.**

In determining the amount of the administrative monetary penalty, the President of the UODO also took into account mitigating circumstances that affect the final amount of the penalty - within the framework of considering the premise from Article 83(2)(k) of Regulation 2016/679 concerning other aggravating or mitigating factors applicable to the circumstances of the case. The President of the UODO - comprehensively examining the case - noted also other circumstances, other than those described above (aggravating) and below (neutral), that could influence the assessment of the violation and the amount of the imposed administrative monetary penalty. The administrator provided the individuals affected by the violation with some information about the incident (by phone - as he explained - apologizing for the occurrence). Such action by the Administrator deserves recognition and acceptance, although it does not exclude potential negative consequences for the Data Subjects resulting from their use. The President of the UODO also took into account that the Administrator commissioned an external entity to conduct a data security analysis regarding the protection of personal data.

Other circumstances indicated below, referred to in Article 83(2) of Regulation 2016/679, after assessing their impact on the violation established in this case, were deemed by the President of the UODO to be neutral in his assessment, meaning they had neither an aggravating nor mitigating effect on the amount of the imposed administrative monetary penalty:

1) Actions taken by the Administrator to minimize the damage suffered by the individuals whose data are concerned [Article 83(2)(c) of Regulation 2016/679]; In the context of this premise, the purpose of the Administrator's action, which is to minimize the damage suffered by the individuals whose data are concerned, is significant. The President of the UODO did not note any such actions by the Administrator in this case. The mere provision of information by phone to the individuals whose data were disclosed about the incident cannot be considered in this case as an action aimed at minimizing the damage suffered by these individuals - however, it was taken into account in the considerations regarding the premise from Article 83(2)(k) of Regulation 2016/679.

2) The degree of responsibility of the administrator, taking into account the technical and

organizational measures implemented by him under Articles 25 and 32 [Article 83(2)(d) of Regulation 2016/679]; Due to the nature of the violation established in this case (failure to report the violation of personal data protection to the President of the UODO and the lack of proper notification of the violation of personal data protection to the individuals from Group B) - which violation in its essence is not related to the technical and organizational measures applied by the administrator - it should be assumed that the premise indicated in Article 83(2)(d) of Regulation 2016/679 does not have either an aggravating or mitigating effect on the amount of the imposed administrative monetary penalty. It is not significant in assessing the Administrator's violation of the provisions of Articles 33(1) and 34(1) and (2) of Regulation 2016/679.

3) Relevant previous violations of the provisions of Regulation 2016/679 by the administrator [Article 83(2)(e) of Regulation 2016/679]; The President of the UODO did not find any previous violations of personal data protection regulations committed by the Administrator, which is why there are no grounds to treat this circumstance as aggravating. And since such a state (compliance with personal data protection regulations) is a natural state resulting from the legal obligations imposed on the Administrator, it cannot also have a mitigating effect on the assessment of the violation made by the President of the UODO.

4) The manner in which the supervisory authority became aware of the violation [Article 83(2)(h) of Regulation 2016/679]; The President of the UODO was informed by a third party about the occurrence of the violation of Article 33(1) and Article 34(1) and (2) of Regulation 2016/679 related to the event of the Administrator disclosing a database containing personal data to an unauthorized recipient. The lack of reporting the violation of personal data protection to the supervisory authority and the proper notification of it to the individuals from Group B is the only... **

the subject of these proceedings and in the circumstances of the considered factual state, the supervisory authority has accepted that it will not treat this premise as an aggravating circumstance.

5) Compliance with previously applied measures in the same case, referred to in Article 58(2) of Regulation 2016/679 [Article 83(2)(i) of Regulation 2016/679]; Prior to issuing this decision, the President of UODO did not apply any measures against the Administrator in the case under consideration as mentioned in Article 58(2) of Regulation 2016/679, which means that the Administrator had no obligation to take any actions related to their application, and such actions, assessed by the President of UODO, could have had an aggravating or mitigating effect on the assessment of the established violation.

6) The application of approved codes of conduct under Article 40 of Regulation 2016/679 or approved certification mechanisms under Article 42 of Regulation 2016/679 [Article 83(2)(j) of Regulation 2016/679]; The Administrator does not apply the instruments referred to in Articles 40 and 42 of Regulation 2016/679. However, their adoption, implementation, and application are not mandatory for administrators and processors, as stipulated by the provisions of Regulation 2016/679, which means that the circumstance of their non-application cannot be considered against the Administrator in this case. On the other hand, the circumstance of adopting and applying such instruments as measures guaranteeing a higher than standard level of protection of processed personal data could be taken into account in favor of the Administrator.

7) Financial benefits obtained directly or indirectly in connection with the violation or avoided losses [Article 83(2)(k) of Regulation 2016/679]; The President of UODO found that the Administrator did not obtain any financial benefits or avoid such losses in connection with the violation. Therefore, there are no grounds to treat this circumstance as aggravating for the Administrator. The establishment of measurable financial benefits resulting from the violation of the provisions of Regulation 2016/679 should be assessed very negatively. On the other hand, the failure of the Administrator to achieve such benefits, as a natural state independent of the violation and its effects, is a circumstance that, by its nature, cannot be mitigating for the Administrator. This is confirmed by the very wording of Article 83(2)(k) of Regulation 2016/679, which requires the supervisory authority to pay due attention to the benefits "achieved" - that occurred on the part of the entity committing the violation.

In the opinion of the President of UODO, the imposed administrative fine fulfills, in the established circumstances of this case, the functions referred to in Article 83(1) of Regulation 2016/679, i.e., it is effective, proportional, and deterrent in this individual case. It should be emphasized that the fine will be effective if its imposition leads to the Administrator, who processes personal data professionally and on a relatively large scale, fulfilling their obligations regarding the protection of personal data in the future, particularly in terms of reporting personal data breaches to the President of UODO and notifying the individuals affected by the breach.

In the opinion of the President of UODO, the administrative fine will serve a repressive function, as it will be a response to the Administrator's violation of the provisions of Regulation 2016/679. It will also serve a preventive function; in the opinion of the President of UODO, it will indicate both to the Administrator and to other data controllers the reprehensibility of neglecting the obligations of controllers related to the occurrence of personal data breaches, which aim to prevent their negative and often severe consequences for the individuals affected by the breach, as well as to eliminate these consequences or at least mitigate them.

Pursuant to the provisions of Article 103 of the Act of May 10, 2018, on the protection of personal data (Journal of Laws of 2019, item 1781), hereinafter referred to as "uodo," the equivalent amounts expressed in euros, referred to in Article 83 of Regulation 2016/679, are calculated in zloty according to the average euro exchange rate announced by the National Bank of Poland in the exchange rate table on January 28 of each year, and in the event that the National Bank of Poland does not announce the average euro exchange rate on January 28 of a given year - according to the average euro exchange rate announced in the nearest exchange rate table of the National Bank of Poland after that date.

Having the above in mind, the President of UODO, based on Article 83(4)(a) in conjunction with Article 103 of uodo, for the violation described in the operative part of this decision, imposed on the Administrator - applying the average euro exchange rate from January 30, 2023 (1 EUR = 4.7160 PLN) - an administrative fine in the amount of 9,903.60 PLN (which is equivalent to 2,100 EUR).

In the opinion of the President of UODO, the imposed fine of 9,903.60 PLN (in words: nine thousand nine hundred three zloty and sixty groszy) meets the criteria referred to in Article 83(1) of Regulation 2016/679 in the established circumstances of this case due to the seriousness of the established violation in the context of the fundamental purpose of Regulation 2016/679 - the protection of the fundamental rights and freedoms of natural persons, in particular the right to the protection of personal data. Referring to the amount of the administrative fine imposed on the Administrator, the President of UODO considered that it is proportional to the financial situation of the Administrator and will not constitute an excessive burden for them. The financial report presented by the Administrator indicates that the value of sold goods and services in 2022 amounted to (...) PLN, which means that the amount imposed

In this administrative matter concerning the monetary penalty, it constitutes approximately (...) % of the aforementioned value of sold goods and services from the aforementioned financial year. At the same time, it is worth emphasizing that the amount of the imposed penalty of 9,903.60 PLN is merely 0.021% of the maximum penalty that the President of the Personal Data Protection Office (UODO) could have imposed on the Administrator for the violations identified in this case, applying the static maximum penalty in accordance with Article 83(4) of Regulation 2016/679 (i.e., 10,000,000 euros).

The amount of the penalty has been set at such a level that, on the one hand, it constitutes an adequate response from the supervisory authority to the degree of violation of the Administrator's obligations, while on the other hand, it does not lead to a situation where the necessity to pay the financial penalty would result in negative consequences, such as a significant reduction in employment or a substantial decrease in the Administrator's turnover. In the opinion of the President of the UODO, the Administrator should and is capable of bearing the consequences of their negligence in the area of data protection.

In this factual and legal state, the President of the Personal Data Protection Office has decided as

stated in the ruling.

[1] B. Adamiak, [in] B. Adamiak, J. Borkowski, Administrative Procedure Code. Commentary, Warsaw 2004, p. 371.

[2] Guidelines of the European Data Protection Board on reporting personal data breaches in accordance with GDPR, version 2.0, hereinafter referred to as Guidelines 9/2022

[3] <https://www.zbp.pl/raporty-i-publikacje/raporty-cykliczne/raport-infodok>

Print article

Metadata

Provider:

Department of Control and Violations

Information created by:

Jan Nowak

2024-01-18

Information entered by:

Wioletta Golańska

2024-02-19 12:16:01

Last modified by:

Edyta Madziar

2024-02-20 08:46:25